

Отчёт по 4-ому этапу индивидуального проекта

Информационная безопасность

Федорова Анжелика Игоревна

Содержание

1	Цель работы	5
2	Задание	6
3	Выполнение лабораторной работы	7
4	Выводы	10

Список иллюстраций

Список таблиц

1 Цель работы

Научиться тестировать веб-приложения с помощью сканера nikto

2 Задание

Использовать nikto

3 Выполнение лабораторной работы

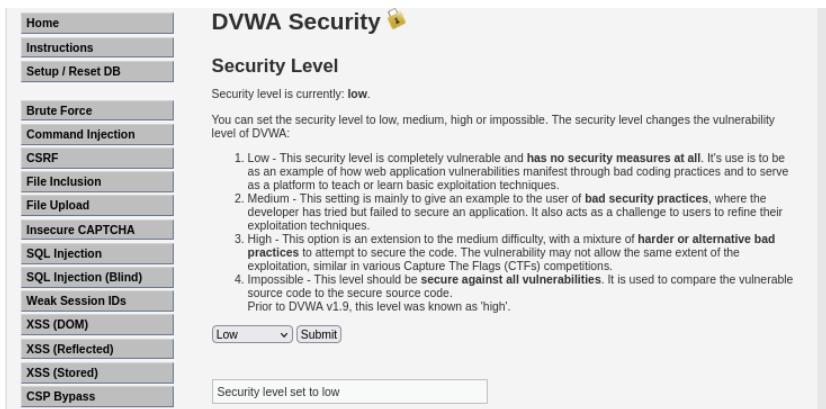
Чтобы работать с nikto, необходимо подготовить веб-приложения, которое будем сканировать.

```
(aifedorova@aifedorova)-[~]
$ sudo systemctl start mysql
[sudo] пароль для aifedorova:
Попробуйте ещё раз.
[sudo] пароль для aifedorova:

(aifedorova@aifedorova)-[~]
$ sudo systemctl start apache2

(aifedorova@aifedorova)-[~]
$
```

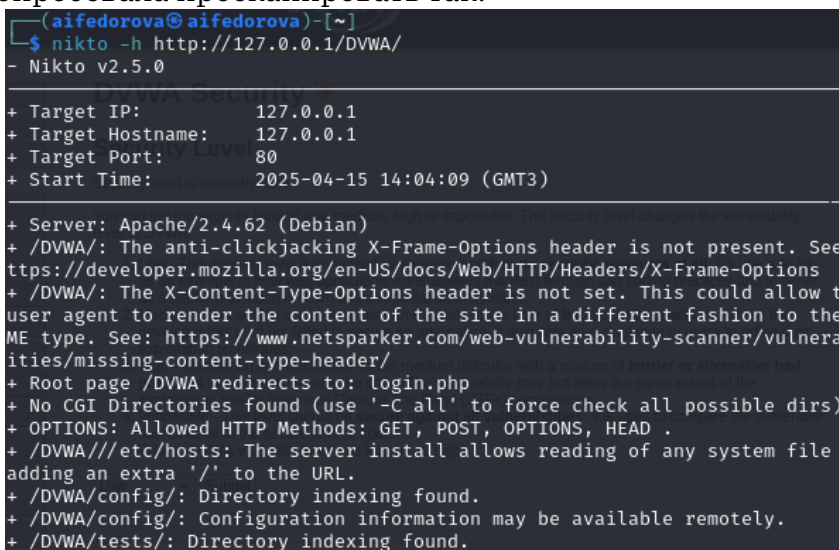
Ввожу в адресной строке браузера адрес DVWA, перехожу в режим выбора уровня безопасности, ставлю минимальный (необязательно, nikto при обычном сканировании для режима impossible и low выдаст одианковые потенциальные уязвимости, что логично, ведь они остаются, но изменяется сложность, с которой их можно использовать



Запускаю nikto



Проверить веб-приложение можно, введя его полный URL и не вводя порт, попробовала просканировать так.



Затем попробовала просканировать введя адрес хоста и адрес порта, результаты незначительно отличаются.


```
(aifedorova@aifedorova)-[~]
$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2025-04-15 14:09:09 (GMT3)

+ Server: Apache/2.4.62 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 62f31af10dbe4, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
```

4 Выводы

Научилась использовать сканер nikto для тестирования веб-приложений